FREE RESOURCE · 2026

# UAE SME Cybersecurity Compliance Checklist 2026

A practical self-assessment guide for UAE businesses navigating NESA, ISO 27001, PDPL, DIFC, ADGM, and PCI DSS compliance requirements.

| ISO 27001:2022 | NESA IAS | PDPL | DIFC | ADGM | PCI DSS v4.0 | 7 Domains · 46 Controls |
|---|---|---|---|---|---|---|



© 2026 Nexaguard Cyberlabs FZCO

## HOW TO USE THIS CHECKLIST

Work through each of the seven compliance domains below. For every control, mark your current status using the Red / Amber / Green (RAG) system. Be honest — this is a self-assessment, not an audit. Use the results to identify your highest-priority gaps and build a remediation plan. If you score Red on any governance, access, or incident response control, treat those as immediate priorities.

This checklist is mapped to the regulatory frameworks most relevant to UAE businesses in 2026. Not all frameworks will apply to every organisation — use the "Frameworks" column to filter what is relevant to your regulatory context.

## RAG STATUS SYSTEM

**● Green — Implemented**
Control is fully in place, documented, and evidenced. You could demonstrate this to an auditor today.

**● Amber — Partial / In Progress**
Control exists in some form but is incomplete, undocumented, or inconsistently applied.

**● Red — Not Implemented**
Control does not exist or is unknown. Treat as a gap requiring immediate attention.

## FRAMEWORKS COVERED

- **ISO/IEC 27001:2022**
- **NESA UAE Information Assurance Standard**
- **UAE PDPL (Personal Data Protection Law)**
- **DIFC Data Protection Law**
- **ADGM Cyber Framework**
- **PCI DSS v4.0 (where applicable)**
- **ADHICS (where applicable)**
- **CBUAE Cybersecurity Framework**

**Note:** This checklist is designed for self-assessment purposes only. It does not constitute a formal gap analysis, audit, or compliance certification. For a formal assessment with documented findings and a remediation roadmap, contact Nexaguard Cyber Labs for a free 30-minute risk review at **www.nexaguardcyberlabs.com**.

01

COMPLIANCE DOMAIN

## Information Security Governance

7 controls · High priority — address any Red items first

| ID | CONTROL DESCRIPTION | FRAMEWORKS | STATUS | NOTES |
|---|---|---|---|---|
| **GOV-01** | Information security policy documented and approved by senior leadership | ISO 27001 NESA | | |
| **GOV-02** | Information security roles and responsibilities formally defined and assigned | ISO 27001 NESA | | |
| **GOV-03** | Formal risk assessment process established, documented, and conducted annually | ISO 27001 NESA DIFC | | |
| **GOV-04** | Security objectives defined and aligned to business goals and regulatory requirements | ISO 27001 ADGM | | |
| **GOV-05** | Annual review of information security policy is scheduled and completed on time | ISO 27001 NESA | | |
| **GOV-06** | Board or executive management receives annual security posture briefing | ISO 27001 DIFC ADGM | | |
| **GOV-07** | Named information security function or owner identified within the organisation | ISO 27001 NESA PCI DSS | | |

02

COMPLIANCE DOMAIN

## Access Control & Identity Management

7 controls

| | | | | |
|---|---|---|---|---|
| **ACC-01** | User access provisioning and deprovisioning process documented and followed | ISO 27001 PCI DSS | | |
| **ACC-02** | Principle of least privilege enforced — users have minimum access required | ISO 27001 NESA PCI DSS | | |
| **ACC-03** | Privileged access accounts inventoried and formally reviewed quarterly | ISO 27001 PCI DSS | | |
| **ACC-04** | MFA enabled for all critical systems, remote access, and admin accounts | ISO 27001 NESA PCI DSS CBUAE | | |
| **ACC-05** | Password policy meets minimum length, complexity, and rotation requirements | ISO 27001 PCI DSS | | |
| **ACC-06** | Dormant and inactive accounts audited and removed within the last 6 months | ISO 27001 NESA | | |
| **ACC-07** | Third-party and vendor access formally reviewed, approved, and time-limited | ISO 27001 PCI DSS PDPL | | |

03

COMPLIANCE DOMAIN

## Asset Management & Data Classification

6 controls · PDPL and ISO 27001 critical

| ID | CONTROL DESCRIPTION | FRAMEWORKS | STATUS | NOTES |
|---|---|---|---|---|
| **AST-01** | Hardware and software asset inventory maintained, current, and owned | ISO 27001 NESA | | |
| **AST-02** | Data classification policy defined with levels (Public / Internal / Confidential / Restricted) | ISO 27001 PDPL DIFC | | |
| **AST-03** | Personal data under PDPL / DIFC is inventoried and data flows are mapped | PDPL DIFC ISO 27001 | | |
| **AST-04** | Data retention and secure disposal policy documented and actively followed | PDPL DIFC ISO 27001 | | |
| **AST-05** | Cloud assets and SaaS applications inventoried and periodically reviewed | ISO 27001 NESA | | |
| **AST-06** | Shadow IT discovery process exists — unauthorised applications are identified | ISO 27001 | | |

04

COMPLIANCE DOMAIN

## Vulnerability Management & Application Security

7 controls · VAPT evidence required by DIFC, ADGM, PCI DSS

| | | | | |
|---|---|---|---|---|
| **VUL-01** | Vulnerability scanning conducted on all systems at least quarterly | ISO 27001 PCI DSS NESA | | |
| **VUL-02** | VAPT conducted in last 12 months on all external-facing systems and applications | ISO 27001 PCI DSS DIFC | | |
| **VUL-03** | Critical vulnerabilities remediated within defined SLA (typically 7–14 days) | ISO 27001 NESA | | |
| **VUL-04** | Patch management process documented and consistently followed across all systems | ISO 27001 PCI DSS NESA | | |
| **VUL-05** | Web Application Firewall (WAF) in place for all public-facing web applications | PCI DSS ISO 27001 | | |
| **VUL-06** | Secure coding practices or DevSecOps controls followed by development teams | ISO 27001 NESA | | |
| **VUL-07** | Penetration test report retained and available as compliance evidence | PCI DSS DIFC ADGM | | |

05

COMPLIANCE DOMAIN

## Incident Response & Business Continuity

8 controls · Breach notification obligations under PDPL and DIFC

| ID | CONTROL DESCRIPTION | FRAMEWORKS | STATUS | NOTES |
|---|---|---|---|---|
| **INC-01** | Incident response plan documented, approved, and accessible to response team | ISO 27001 NESA PDPL | | |
| **INC-02** | Incident severity classification framework defined (P1/P2/P3 or equivalent) | ISO 27001 NESA | | |
| **INC-03** | Key contacts for incident response identified — internal team and external support | ISO 27001 | | |
| **INC-04** | Incident response plan tested in last 12 months (tabletop exercise or live drill) | ISO 27001 NESA | | |
| **INC-05** | Business Continuity Plan (BCP) documented with roles and recovery procedures | ISO 27001 DIFC CBUAE | | |
| **INC-06** | Disaster Recovery Plan with defined RTOs and RPOs per critical system | ISO 27001 PCI DSS | | |
| **INC-07** | Backup and recovery process tested successfully within the last 6 months | ISO 27001 PCI DSS | | |
| **INC-08** | Breach notification obligations under PDPL / DIFC are understood and documented | PDPL DIFC | | |

06

COMPLIANCE DOMAIN

## Human Risk & Security Awareness

6 controls · ISO 27001 Annex A.6.3 requirement

| | | | | |
|---|---|---|---|---|
| **HUM-01** | Security awareness training programme exists and is formally documented | ISO 27001 NESA | | |
| **HUM-02** | All staff complete security awareness training as part of onboarding | ISO 27001 PDPL | | |
| **HUM-03** | Annual security awareness refresher training completed by all staff | ISO 27001 NESA | | |
| **HUM-04** | Phishing simulation exercise conducted and results reviewed in last 12 months | ISO 27001 NESA | | |
| **HUM-05** | High-risk roles (finance, IT, executives) receive tailored role-specific training | ISO 27001 | | |
| **HUM-06** | Acceptable Use Policy (AUP) acknowledged and signed by all staff | ISO 27001 NESA | | |

07

COMPLIANCE DOMAIN

# Third-Party & Supply Chain Security

6 controls · PDPL requires DPAs with all personal data processors

| ID | CONTROL DESCRIPTION | FRAMEWORKS | STATUS | NOTES |
|---|---|---|---|---|
| **TPR-01** | Vendor and third-party risk assessment process documented and followed | ISO 27001<br>NESA<br>PCI DSS | ○○○ | |
| **TPR-02** | Critical vendors assessed for security posture before onboarding | ISO 27001<br>DIFC ADGM | ○○○ | |
| **TPR-03** | Data Processing Agreements (DPAs) in place with all vendors handling personal data | PDPL DIFC<br>ISO 27001 | ○○○ | |
| **TPR-04** | Cloud provider security certifications reviewed (ISO 27001, SOC 2 or equivalent) | ISO 27001<br>NESA | ○○○ | |
| **TPR-05** | Vendor and third-party system access reviewed, approved, and limited in scope | ISO 27001<br>PCI DSS | ○○○ | |
| **TPR-06** | Annual review of third-party risk register conducted and findings acted upon | ISO 27001<br>DIFC | ○○○ | |

## SCORING & INTERPRETATION

### Mostly Green

Strong compliance posture. Focus on continuous monitoring, evidence collection, and annual reviews. Consider ISO 27001 certification as a next step.

### Significant Amber

Implementation gaps exist. Prioritise a remediation roadmap. Amber governance and access controls should be upgraded to Green within 90 days.

### Any Red Items

Immediate action required. Red items in governance, access control, and incident response represent the highest regulatory and operational risk.

**Three Recommended Next Steps**

01 Address all Red items in governance (GOV) and access control (ACC) domains first — these carry the highest risk and the most regulatory scrutiny.
02 Book a Nexaguard free risk review at www.nexaguardcyberlabs.com for formal gap analysis and a written remediation roadmap.
03 Download the Web Application Security Hardening Guide from www.nexaguardcyberlabs.com for technical controls to address VUL domain gaps.

NEXT STEPS

# Need help turning these findings into a remediation plan?

Nexaguard offers a free 30-minute risk review — a conversation with a senior practitioner. No commitment, no hard sell. You leave with clarity on your highest-priority gaps and a recommended path forward.

**Book Free Risk Review** | **www.nexaguardcyberlabs.com**

+971 50 623 3538
info@nexaguardcyberlabs.com
Dubai Digital Park, Dubai Silicon Oasis, UAE

This document is for self-assessment purposes only and does not constitute a formal audit or compliance certification. For formal assessments, contact Nexaguard Cyberlabs. © 2026 Nexaguard Cyberlabs FZCO. IFZA Freezone Registered Entity, Dubai, UAE.